CHUYÊN ĐỀ TỐT NGHIỆP

MẠNG MÁY TÍNH

ỨNG DỤNG QUẢN LÝ MÁY TÍNH TRẺ EM

OPEN GUARDIAN KIDS

SINH VIÊN THỰC HIỆN

Nguyễn Minh Hoàng · 23127368

Lê Văn Hoàng Tấn · 23127471

VẤN ĐỀ THỰC TIỄN & GIẢI PHÁP TIẾP CẬN

Từ giám sát xâm lấn sang bảo vệ ở tầng hệ thống và mạng

CÁCH TIẾP CẬN CÒN HẠN CHẾ

01 Dễ bị vô hiệu hóa

Đổi giờ Windows, đổi DNS, gỡ extension

02 Giám sát xâm lấn

Keylogger, chụp màn hình → mất riêng tư

03 Chi phí và phụ thuộc

Chi phí cao, hạ tầng ngoài nước

HƯỚNG TIẾP CẬN OPEN GUARDIAN KIDS

✓ **DNS SINKHOLE · UDP 53**

Lọc tên miền tại tầng mạng, độc lập trình duyệt

✓ **ĐỒNG HỒ ĐƠN ĐIỆU**

time.monotonic() không bị chỉnh lùi giờ

✓ **PRIVACY BY DESIGN**

Không chụp màn hình, không keylogger

TƯ DUY CỐT LÕI — **Bảo vệ thiết bị • An toàn mạng • Tôn trọng quyền riêng tư**

HIẾN CHƯƠNG ĐẠO ĐỨC & KHUNG PHÁP LÝ

Sáu nguyên tắc được chuyển hóa thành các chức năng và công cụ thiết kế.

NT1 — **KHÔNG CHỤP MÀN HÌNH**
No Screenshot

NT2 — **KHÔNG GHI PHÍM**
No Keylogger

NT3 — **MINH BẠCH**
Hiển thị rõ ràng, đơn giản

TRẺ EM
LÀ TRỌNG TÂM

NT4 — **KHÓA NHÂN VĂN**
Ẩn hạn 60 giây

NT5 — **TIẾNG NÓI CỦA TRẺ**
Xin giờ / báo chặn nhầm

NT6 — **VÙNG AN TOÀN**
Whitelist giáo dục

TRỤ CỘT PHÁP LÝ
Luật Trẻ em 2016 • NĐ 13/2023/NĐ-CP

TRỤ CỘT AN TOÀN KỸ THUẬT
NIST SP 800-63B • OWASP ASVS v4

Thiết kế lấy quyền riêng tư, minh bạch và an toàn của trẻ làm nền tảng

KIẾN TRÚC PHÂN TÁN 3 KHỐI TỔNG THỂ

Mô hình 3 tầng giúp hệ thống dễ quản trị, mở rộng và đồng bộ thời gian thực.

KHỐI MÁY CON
Protected Client Tier



- Core Service (Session 0)
- Tray UI (Session 1)
- DNS Proxy :53
- AppController
- SQLite Cache

Thiết bị được bảo vệ và giám sát cục bộ.

HTTPS / WSS

LỆNH KHẨN CẤP
WSS < 5s

KHỐI MÁY CHỦ TRUNG TÂM
Central Server Tier

- FastAPI REST APIs
- WebSocket Hub
- Retention Scheduler
- PostgreSQL / Cloud DB

Xử lý nghiệp vụ, đồng bộ dữ liệu và điều phối lệnh.

HTTPS / WSS

KHỐI BẢNG ĐIỀU KHIỂN
Parent Dashboard Tier



- Responsive Web UI
- JWT HttpOnly Auth
- Mobile / PC Access

Phụ huynh theo dõi và điều khiển từ xa.

Client: Bảo vệ tại máy con

Server: Đồng bộ & điều phối

Dashboard: Giám sát mọi nơi

Kênh truyền thông liên tầng: HTTPS cho API đồng bộ, WSS cho lệnh thời gian thực.

KIẾN TRÚC WINDOWS SESSION 0 ISOLATION

Tách dịch vụ bảo vệ khỏi giao diện người dùng để hạn chế thao tác tắt Agent.

SESSION 0 • SYSTEM

Dịch vụ nền (non-interactive)

CORE SERVICE	Điều phối chính sách
DNS PROXY :53	Lọc tên miền cục bộ
APP CONTROLLER	Kiểm soát tiến trình
SQLITE CACHE	Lưu dữ liệu ngoại tuyến

IPC
Named Pipe / Loopback

SESSION 1 • USER

Desktop tương tác của trẻ

TRAY UI	Biểu tượng khay hệ thống
ĐỒNG HỒ	Hiển thị thời gian còn lại
HỘP THOẠI	Xin thêm giờ / báo chặn nhầm

TÌNH HUỐNG: Trẻ bấm “End Task” trong Task Manager → Windows kiểm tra quyền và từ chối nếu tài khoản không đủ quyền.

Lưu ý: Session 0 không tự bảo đảm chống tắt; phải cấu hình Service ACL và tài khoản Standard.

NGĂN XẾP CÔNG NGHỆ & GIAO THỨC MẠNG

Các thành phần chính được tổ chức theo tầng, từ giao diện đến hệ thống và dữ liệu.

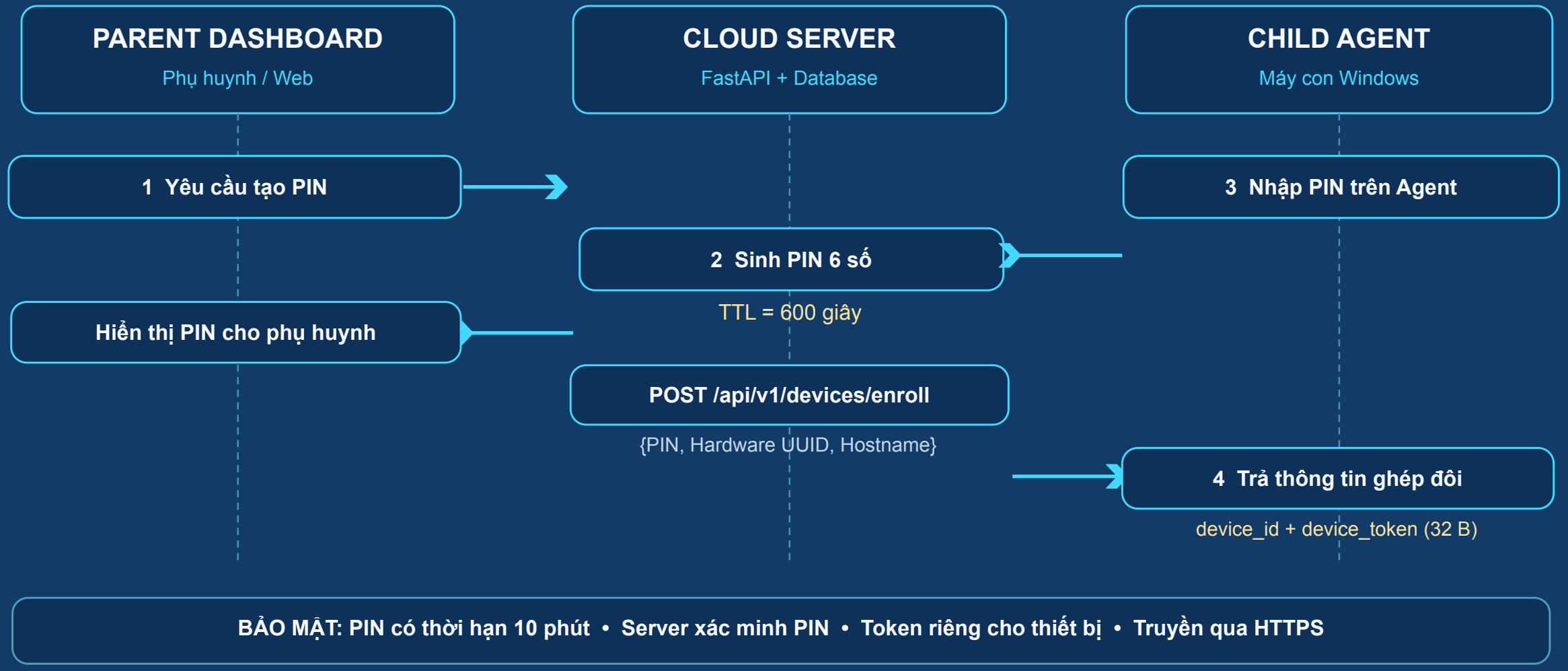
01	**TẦNG TRÌNH BÀY**	Parent Web Dashboard • Child Tray UI (Tkinter) HTML5 / CSS • pystray
02	**TẦNG ỨNG DỤNG**	FastAPI REST • WebSocket Hub • AppController Uvicorn ASGI • SQLAlchemy 2.0 • Pydantic v2
03	**TẦNG GIAO THỨC & BẢO MẬT**	HTTPS / TLS 1.3 • WSS (RFC 6455) • UDP :53 Argon2id • AES-256-GCM • HMAC-SHA256 • JWT
04	**TẦNG HỆ THỐNG & DỮ LIỆU**	Windows Win32 API • Raw UDP Socket • psutil SQLite 3 (Edge) • Neon PostgreSQL (Cloud)

CLIENT → SERVER	HTTPS (REST) + WSS (lệnh realtime)
DNS CỤC BỘ	UDP/53 → 127.0.0.1

Thông điệp: giao tiếp liên tầng được bảo vệ bằng TLS; lọc DNS và dữ liệu đệm tại thiết bị.

GIAO THỨC GHÉP ĐÔI THIẾT BỊ AN TOÀN

Ghép nối máy con với phụ huynh bằng PIN 6 số có thời hạn, không nhập mật khẩu trên máy trẻ.



GIÁM SÁT TRẠNG THÁI & HEARTBEAT

Cơ chế nhịp tim định kỳ giúp phát hiện trạng thái thiết bị, không cần quét Ping qua NAT.

01 CHILD AGENT

Mỗi 60 giây gửi POST /heartbeat
CPU (%) • RAM (MB)
Uptime (s) • Agent version

02 CLOUD SERVER

Xác thực thiết bị, nhận dữ liệu
Cập nhật devices.last_seen_at
Lưu viễn trắc tối thiểu

03 PARENT DASHBOARD

Hiển thị trạng thái kết nối
CPU / RAM / Phiên bản
Thời điểm liên lạc cuối

QUY TẮC PHÂN LOẠI TRẠNG THÁI

$$\Delta t = NOW() - last_seen_at$$

$\Delta t \leq 120$ s → ONLINE

$\Delta t > 120$ s → OFFLINE

Heartbeat: 60 s • Ngưỡng offline: 120 s • Không phụ thuộc ICMP Ping

BỘ ĐẾM GIỜ ĐƠN ĐIỆU & NHẬN DIỆN IDLE

Chống việc thay đổi giờ Windows làm sai thời gian sử dụng; tạm dừng khi người dùng rời máy.

ĐỒNG HỒ ĐƠN ĐIỆU

time.monotonic()
Không bị chỉnh lùi bởi thay đổi giờ hệ thống.
Δt = monotonic_now − monotonic_prev

PHÁT HIỆN NHÀN RỖI

Win32 GetLastInputInfo()
Đo khoảng thời gian không có chuột / phím
Idle > 300 giây → tạm dừng cộng giờ

LUỒNG XỬ LÝ TÍCH LŨY

LẤY MẪU
monotonic()

→

KIỂM TRA
Idle > 300s?

→

ACTIVE
used_seconds += Δt

→

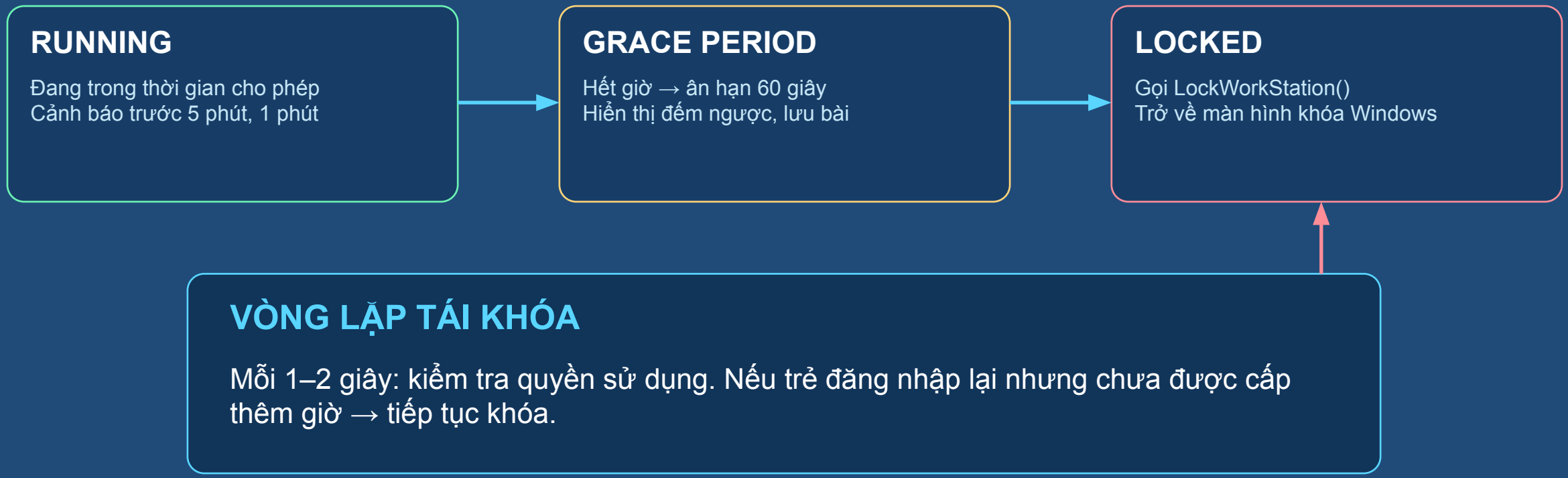
LƯU ĐỆM
SQLite / 30s

Nếu Idle > 300 s: không cộng thời gian • Nếu Active: cộng Δt • Khởi động lại: phục hồi từ SQLite

Lưu ý: đồng hồ monotonic cần kết hợp dữ liệu bền vững để duy trì số giờ đã dùng sau khởi động lại.

MÁY TRẠNG THÁI KHÓA MÁY NHÂN VĂN

Cảnh báo trước khi hết giờ, cho trẻ 60 giây để lưu công việc rồi mới khóa phiên Windows.



Chỉ dừng tái khóa khi có chính sách hợp lệ hoặc phụ huynh cấp thêm thời gian.

LỆNH THỜI GIAN THỰC & HMAC-SHA256

Kênh WSS truyền lệnh từ phụ huynh đến Agent, đồng thời xác minh tính toàn vẹn và hạn chế phát lại.

1. PHỤ HUYNH
Nhấn Khóa ngay / +30 phút

→

2. SERVER
Đóng gói payload + timestamp

→

3. WSS
Truyền bản tin thời gian thực

→

4. AGENT
Kiểm tra HMAC + timestamp

→

5. THỰC THI
Áp dụng lệnh hợp lệ

CHỮ KÝ TOÀN VẸN

HMAC-SHA256(device_token, payload + timestamp)

Kiểm tra chênh lệch thời gian ≤ 60 s và từ chối chữ ký sai

Lệnh mục tiêu < 5 s theo tài liệu thiết kế; độ trễ thực nghiệm cần đối chiếu với log đo.

TIẾNG NÓI CỦA TRẺ & TƯƠNG TÁC HAI CHIỀU

Tray UI giúp trẻ biết giới hạn sử dụng và chủ động trao đổi với phụ huynh, không giám sát bí mật.



1. GỬI YÊU CẦU

Trẻ chọn 15 / 30 / 60 phút và nêu lý do; hoặc báo website bị chặn nhầm

2. PHỤ HUYNH DUYỆT

Server ghi nhận yêu cầu → Dashboard hiển thị để phụ huynh ra quyết định

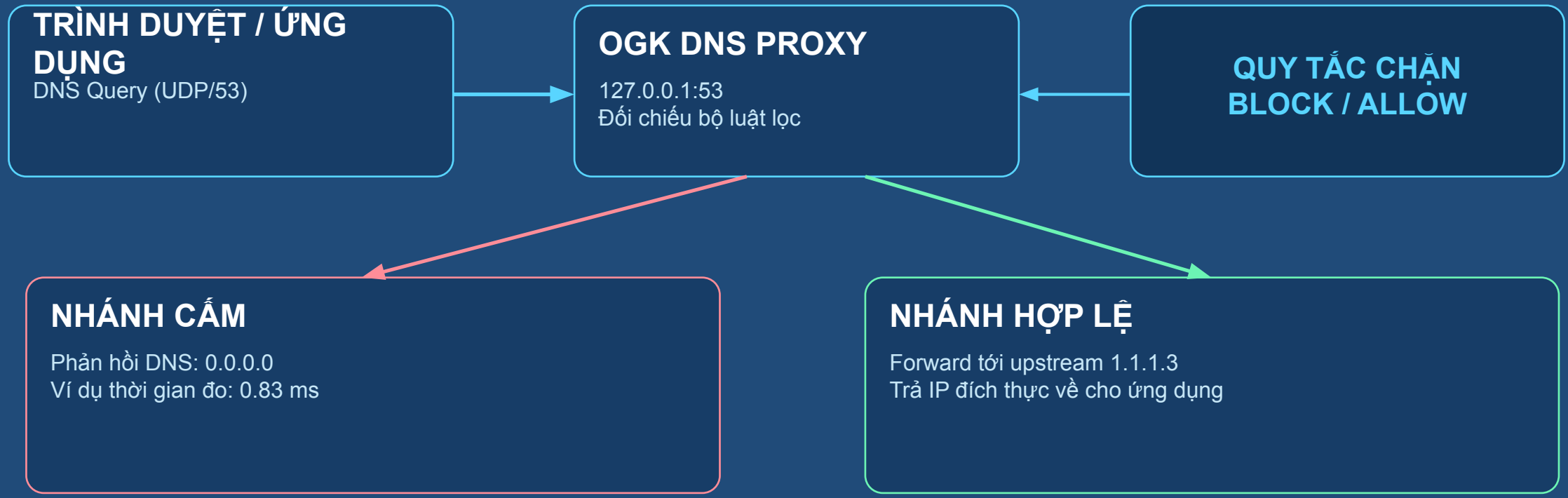
3. ĐỒNG BỘ VỀ MÁY CON

Server gửi lệnh qua WebSocket → Agent cập nhật giờ / phản hồi kết quả

Nguyên tắc NT3 và NT5: minh bạch thời gian, hỗ trợ yêu cầu và báo chặn nhầm.

DNS SINKHOLE PROXY UDP 53 (M1)

Phân luồng truy vấn DNS ngay trên máy con: chặn tên miền cấm, chuyển tiếp tên miền hợp lệ.



Thiết kế DNS hệ thống: card mạng cấu hình máy chủ DNS nội bộ; kết quả phụ thuộc đường đi DNS thực tế.

WILDCARD SUBDOMAIN & WHITELIST NT6

Khớp tên miền gốc và tên miền phụ theo ranh giới dấu chấm; bảo vệ danh sách giáo dục ưu tiên.

LUẬT CHẶN: tiktok.com

Khớp chính xác: tiktok.com
Khớp phụ: vt.tiktok.com, api.tiktok.com
Không khớp: nottiktok.com

DANH SÁCH BẢO VỆ NT6

tongdai111.vn • moet.gov.vn
chinhphu.vn • edu.vn
Từ chối thao tác chặn thuộc danh mục bảo vệ

ĐIỀU KIỆN KHỚP TÊN MIỀN

$$\text{Match}(Q,D) \Leftrightarrow (Q = D) \ \text{OR} \ Q.\text{endsWith}(\text{"."} + D)$$

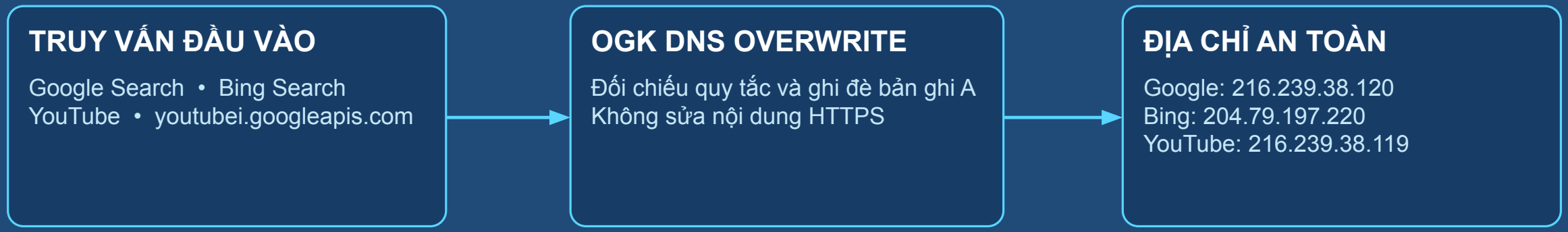
BLOCKED • tiktok.com và các subdomain thật sự

PROTECTED • NT6 immutable whitelist

Danh sách miễn nhiễm được áp dụng trước quy tắc chặn để bảo vệ quyền tiếp cận tài nguyên thiết yếu.

GHI ĐÈ DNS: SAFESEARCH & YOUTUBE

Ánh xạ truy vấn DNS sang địa chỉ chế độ tìm kiếm an toàn ở cấp độ mạng.



CƠ CHẾ ÁNH XẠ

google.com → forcesafesearch.google.com • bing.com → strict.bing.com

youtube.com → restrict.youtube.com | Trình duyệt phải sử dụng đường DNS do OGK quản lý

Các IP trong tài liệu là giá trị cấu hình ví dụ; cần xác minh khi triển khai thực tế.

CANARY DOMAIN & PHẢN HỒI NXDOMAIN

Cơ chế phát tín hiệu chính sách DNS của mạng nội bộ tới ứng dụng có hỗ trợ Canary.

01 TRÌNH DUYỆT
Thử truy vấn canary domain

→

02 OGK DNS PROXY
Nhận DNS query qua :53

→

03 PHẢN HỒI
NXDOMAIN / RCODE = 3

→

04 FALLBACK
Ứng dụng hỗ trợ quay về DNS hệ thống

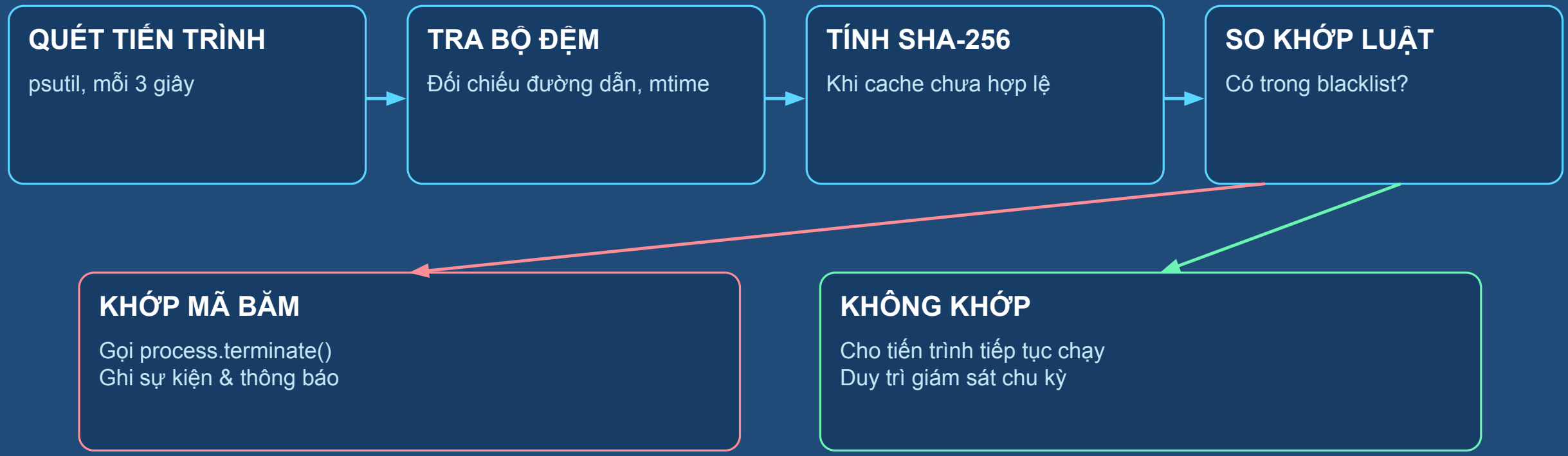
CANARY DOMAIN

use-application-dns.net

Giới hạn: Canary không tự vô hiệu hóa mọi cấu hình DoH, VPN hoặc mọi trình duyệt.

KIỂM SOÁT ỨNG DỤNG BẰNG SHA-256

Nhận diện file thực thi theo nội dung nhị phân thay vì chỉ dựa trên tên tiến trình.



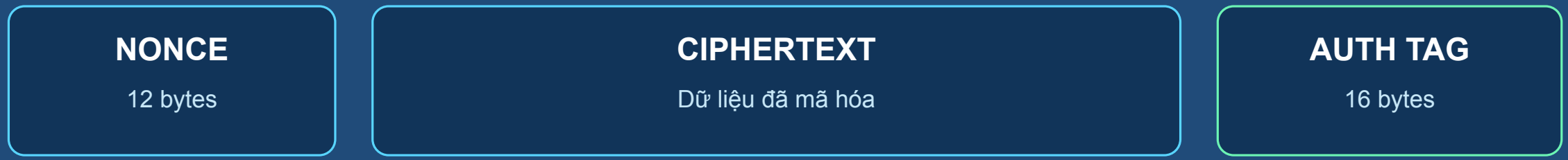
Cache (mtime, SHA-256) giúp giảm băm lại; CPU 0.0% là số liệu báo cáo, không phải bảo đảm mọi máy.

BẢO MẬT XÁC THỰC & MÃ HÓA AES-256-GCM

Pipeline xác thực phụ huynh và cấu trúc bản tin mã hóa có kiểm tra tính toàn vẹn.



BẢN TIN AES-256-GCM (AEAD)



Thông số khóa, ngưỡng giới hạn và cấu hình Argon2id cần đối chiếu mã nguồn triển khai.

CHỐNG IDOR & QUYỀN XÓA DỮ LIỆU

Kiểm tra quyền sở hữu thiết bị trước khi thực thi API; hỗ trợ xóa dữ liệu ở Cloud và máy con.

01 AUTHORIZATION / CHỐNG IDOR

Parent A yêu cầu device_id

↓

Đối chiếu device.parent_id

↓

Khác chủ sở hữu → HTTP 403

02 RIGHT TO ERASURE

1. Phụ huynh xác thực yêu cầu

↓

2. Server xóa dữ liệu Cloud

↓

3. WSS: purge_local_data

↓

4. Agent xóa SQLite và xác nhận

Các audit log còn được giữ phải tuân theo chính sách lưu giữ và yêu cầu pháp lý áp dụng.

MA TRẬN 7 LỚP PHÒNG THỦ CHỐNG VƯỢT RÀO

M3 Anti-Bypass Guard · Phòng thủ nhiều lớp, không phụ thuộc một cơ chế đơn lẻ

01	**DNS Watchdog**	Phát hiện đổi DNS; khôi phục 127.0.0.1 · chu kỳ 20s
02	**Canary NXDOMAIN**	Áp dụng cho trình duyệt hỗ trợ tín hiệu canary
03	**Kiểm soát DoT / DoH**	Chặn theo chính sách phù hợp; không bảo đảm bao phủ toàn bộ
04	**VPN Process Guard**	Nhận diện ứng dụng được liệt kê bằng SHA-256
05	**Monotonic Time**	Thời gian sử dụng không lệ thuộc chỉnh đồng hồ Windows
06	**Service Isolation**	Core Service chạy ở Session 0 với quyền phù hợp
07	**Windows Standard User**	Hạn chế thay đổi cấu hình hệ thống, bảo vệ tài khoản Admin

MÔ HÌNH PHÒNG THỦ

NETWORK

↓

PROCESS / TIME

↓

WINDOWS SERVICE

GIỚI HẠN CẦN KIỂM THỬ

- DoH / VPN / truy cập IP trực tiếp
- Quyền Administrator và Safe Mode
- Thay đổi DNS bằng nhiều card mạng
- Khôi phục sau khi agent lỗi

Phòng thủ theo chiều sâu giúp tăng độ khó vượt rào — không đồng nghĩa an toàn tuyệt đối.

KIẾN TRÚC CHỊU LỖI NGOẠI TUYẾN & TỰ PHỤC HỒI

M5 · Agent tiếp tục thực thi chính sách khi mất Internet hoặc server không khả dụng

ONLINE NORMAL

Heartbeat · HTTPS · WSS
Nhận quy tắc mới và đồng bộ sự kiện

MẤT KẾT NỐI →

← KẾT NỐI PHỤC HỒI

OFFLINE AUTONOMOUS

Đếm giờ cục bộ · áp dụng chính sách đã lưu
Ghi hàng đợi sự kiện SQLite

SYNC RECOVERY

Bulk sync + đánh dấu đã nhận

MẤT INTERNET

Ghi sự kiện cục bộ; thử gửi lại

SERVER GIÁN ĐOẠN

Duy trì giới hạn giờ đã đồng bộ

TẮT NGUỒN ĐỘT NGỘT

Khôi phục trạng thái từ SQLite

Yêu cầu triển khai: lưu bền vững định kỳ, chống gửi trùng, giới hạn hàng đợi và giải quyết xung đột.

KẾT LUẬN & HƯỚNG PHÁT TRIỂN

Open Guardian Kids · Quản trị thiết bị, an toàn mạng và tôn trọng quyền riêng tư

ĐÓNG GÓP CỐT LÕI

- Quản lý thời gian với đồng hồ đơn điệu
- Lọc mạng DNS và kiểm soát ứng dụng
- Điều khiển từ xa qua HTTPS / WSS
- Thiết kế tôn trọng quyền riêng tư

HƯỚNG PHÁT TRIỂN

- Ứng dụng phụ huynh trên thiết bị di động
- AI cục bộ hỗ trợ phân loại tên miền
- Mở rộng agent cho macOS / Linux
- Kiểm thử bảo mật và hiệu năng thực tế

GIÁ TRỊ CỐT LÕI: Bảo vệ trẻ em • Hỗ trợ phụ huynh • Tôn trọng quyền riêng tư

CẢM ƠN MỌI NGƯỜI ĐÃ LẮNG NGHE

Q&A